

CONTOSO

Incident Response Playbook

Operations & Technology Division
Version 3.1 — For use by Contoso Operations staff

Purpose	Classify, assess, and route operational incidents consistently
Audience	Operations staff, on-call engineers, operations managers
Scope	All incidents affecting Contoso production systems and services
Review cycle	Quarterly — next review Q3 2026

1. Purpose and Scope

This playbook defines how Contoso classifies, assesses, escalates, and resolves operational incidents. It applies to all incidents affecting production systems, client-facing services, internal infrastructure, data assets, and security. All operations staff and on-call engineers are expected to follow this playbook when handling any incident report.

The playbook is also used as a knowledge base for the Contoso Incident Coordinator agent, which uses this document to classify incoming incidents, assess severity, determine escalation paths, and generate management summaries. Every section of this document may be retrieved and used by the agent when processing an incident report.

Important: When in doubt between two severity levels, always choose the higher one. Conservative escalation is preferable to under-escalation. A missed backup is never Low severity. An alert with no business context always has missing information.

2. Incident Classification Taxonomy

Every incident must be assigned exactly one classification from the following list. If an incident could fit multiple categories, choose the one that best describes the primary impact or root cause.

2.1 Infrastructure

Incidents affecting servers, networks, storage, cloud resources, or platform services. Includes: server outages, high CPU/memory/disk utilisation, network failures, DNS issues, cloud service disruptions, load balancer failures, certificate expiration, hardware failures, and infrastructure-level monitoring alerts.

Examples:

- Server CPU >90% for sustained period
- Database server unreachable
- Network link failure between data centres
- SSL certificate expired on production endpoint
- Cloud region unavailability affecting hosted services

2.2 Application

Incidents caused by software behaviour, code defects, deployment failures, or application-level errors. Includes: API errors, service timeouts, failed deployments, incorrect outputs, performance degradation in specific services, and third-party integration failures.

Examples:

- Payment API returning 503 errors after deployment
- Reporting module loading slowly for all users
- Scheduled job failing to complete
- Third-party API integration returning unexpected responses
- Application throwing unhandled exceptions

2.3 Security

Incidents involving potential or confirmed unauthorised access, data exposure, vulnerability exploitation, malicious activity, or policy violations. Includes: login anomalies, unusual access patterns, suspected credential compromise, malware detection, unusual data transfers, and phishing attempts.

Examples:

- Spike in failed login attempts from unusual IP ranges
- Privileged account accessed from unrecognised geography
- Unexpected outbound data transfer detected
- User reports receiving suspicious internal emails
- Security scanner alerts on known vulnerability

2.4 Data

Incidents affecting data integrity, availability, backup processes, data pipelines, or data quality. Includes: backup failures, ETL pipeline errors, data corruption, data loss, replication failures, and data access issues.

Examples:

- Nightly backup job did not complete
- Data pipeline failed to process records overnight
- Reports showing incorrect or stale data
- Database replication lag exceeding threshold
- File storage quota exceeded causing write failures

2.5 User Error

Incidents that, on investigation, are caused by incorrect user action rather than a system or application defect. Includes: misconfigured settings, incorrect data entry, permission requests that are procedural not technical, and training gaps. These still require a response but are not system defects.

Examples:

- User cannot access system they were never granted access to
- Report shows no data because date filter was set incorrectly
- User locked out after multiple incorrect password attempts
- Request to reset a password or restore deleted content
- Complaint about feature that works as designed

2.6 Unknown

Use this classification only when there is insufficient information to classify the incident into any of the above categories, and the assessment includes specific questions in the Missing information field to enable reclassification. Always aim to reclassify as soon as more information is available.

Examples:

- Incident report with no system, service, or symptom specified
- Automated alert with no accompanying context
- Second-hand report with no direct observation

3. Severity Definitions

Severity reflects the current or potential business impact of the incident, not just the technical nature of the problem. Assess severity based on the information available at the time of the report. If in doubt, escalate higher.

Severity	Risk Score	Definition	Urgency	Examples
Critical	8–10	Complete or imminent loss of a core business service or data. Revenue processing halted. Customer, data, or system disruption.	Less than 1 hour	Payment processing down for multiple users. Workaround not available.
High	5–7	Significant degradation of a business service. Partial loss of functionality affects multiple users. Workaround available.	Within 2 hours	Reporting system slow for multiple users. Workaround exists.
Medium	3–4	Limited degradation affecting a subset of users or a non-critical business process. Workaround exists.	Within 8 hours	Calendar sync issue for some users. Workaround exists.
Low	1–2	Cosmetic or minor issue with no functional impact. Single user affected. No business process disruption.	Next business day	UI typo on internal tool. No business impact.

3.1 Severity Escalation Rules

Severity must be re-assessed if the situation changes. The following conditions require immediate escalation to Critical regardless of the original assessment:

- Any incident involving confirmed or suspected data loss or exposure
- Any incident affecting payment processing, customer authentication, or financial reporting
- Any incident where the estimated time to resolution exceeds 2 hours
- Any incident where a workaround is no longer available
- Any automated alert that cannot be explained within 15 minutes of investigation
- Any backup failure — regardless of how it is reported — that spans more than one cycle

3.2 Risk Score Guidance

The risk score (1–10) quantifies business impact. Use the following factors to calibrate the score. A score of 8 or higher triggers the Critical escalation path regardless of other fields.

Factor	High risk (+3)	Medium risk (+2)	Low risk (+1)
Users affected	All users or external customers	Multiple internal teams	Single user
Service type	Revenue-generating or customer-facing business process	Internal business process	Non-critical or dev/test
Data risk	Data loss or exposure possible	Data quality degraded	No data risk
Recovery time	Unknown or >4 hours	1–4 hours	<1 hour with known fix
Recurrence	Second or more occurrence	First time for this system	Never seen before (low context)

4. Escalation Paths

The escalation path specifies who should own the incident — the first named team or role is the primary owner. Escalation paths are determined by incident type and severity. The incident coordinator agent should always recommend the most specific applicable path.

Classification	Critical	High	Medium / Low
Infrastructure	On-call Infrastructure Lead + VP Engineering (notify)	Infrastructure Team	Infrastructure Team (next business day)
Application	On-call Application Lead + Product Owner (notify)	Application Support L2	Application Support L1
Security	Security Response Team + CISO (notify) + Legal (notify)	Security Response Team	Security Operations
Data	On-call Infrastructure Lead + Data Engineering Lead + DPO (notify if personal data)	Data Engineering Team	Data Engineering Team (scheduled)
User Error	N/A — re-classify if true Critical	Operations Support	Help Desk
Unknown	On-call Infrastructure Lead (pending classification)	Operations Support (pending classification)	Help Desk (pending classification)

4.1 Security Incident Escalation — Special Rules

Security incidents follow a separate escalation protocol regardless of the initial severity assessment. Any incident classified as Security must be reported to the Security Response Team immediately, even if the initial severity is Low. Security incidents are the only category where the escalation path overrides the urgency mapping.

- Never communicate details of a security incident over email or Teams until Security Response Team approves
- All security incidents must be logged in the Security Incident Register (separate from general Incidents table)
- The DPO must be notified within 1 hour if personal data may have been accessed or exported
- External regulatory notification may be required within 72 hours — Security Response Team owns this decision

4.2 Backup Failure Escalation — Special Rules

Backup failures are classified as Data incidents and follow a specific escalation rule based on the number of missed cycles:

Missed backup cycles	Severity	Escalation path
1 cycle (first miss)	High	Data Engineering Team — investigate within 2 hours
2 cycles	Critical	On-call Infrastructure Lead + Data Engineering Lead
3 or more cycles	Critical	On-call Infrastructure Lead + Data Engineering Lead + VP Engineering (notify)
Unknown number of cycles	Critical (conservative)	On-call Infrastructure Lead — treat as 2+ cycles until confirmed

Key rule: A backup failure reported as 'probably fine' or 'just wanted to mention it' is still a backup failure. The reporter's tone does not affect the severity assessment. When the number of missed cycles is unknown, assume worst case and escalate to Critical.

5. Missing Information Assessment

Every incident assessment must include a Missing information field. The purpose is not to delay response — the assessment and escalation should proceed with available information. Missing information should be gathered in parallel by the assigned team. The more specific the missing information list, the faster the assigned team can resolve the incident.

5.1 Universal missing information checklist

These pieces of information are relevant for any incident type if not stated:

- When did the incident start? (exact time or first observed time)
- How many users or systems are affected? (specific number or 'all')
- Is this a first occurrence or a recurrence? (if recurrence, how many times?)
- Is there a workaround in place? (if yes, what is it and how sustainable?)
- What changed recently? (deployment, configuration change, data import)
- What is the business process that depends on the affected system?

5.2 Classification-specific missing information

Infrastructure incidents

- Which specific server, service, or resource is affected? (hostname, IP, or service name)
- What is the current utilisation / threshold value? (for capacity alerts)
- Is the issue isolated to one node or affecting multiple nodes?
- When was the last successful operation for this resource?
- Is there an associated monitoring alert ID?

Application incidents

- Which specific application, service, or API endpoint is affected?
- What is the exact error message or HTTP status code?
- When was the last successful deployment and what was changed?
- Are logs available and who has access to them?
- Is the issue affecting all requests or a subset (by user, region, or feature)?

Security incidents

- What specific behaviour triggered the report? (exact alert text, observed action)
- Which account, system, or data asset is involved?
- When was the suspicious activity first observed?
- Has the affected account or system been isolated?
- Is there any indication of data export or transfer?

Data incidents

- Which dataset, pipeline, or backup job is affected?
- What is the expected vs actual state? (e.g. backup file size, record count)
- How many cycles or runs have been missed or failed?
- Is data corruption confirmed or suspected?
- What downstream processes or reports depend on this data?

Automated alerts

- What is the business service that depends on the alerted resource?
- Has the alert been investigated? What did the investigation show?
- Is this the first time this alert has fired, or is it recurring?
- What is the expected resolution or acknowledgement time for this alert type?

6. Recommended Immediate Actions

The Recommended action field in an incident assessment should always be specific and executable. Avoid generic actions like 'investigate the issue' or 'contact the team'. A recommended action should tell a responder exactly what to do in the first 15 minutes.

Incident type + severity	First recommended action
Infrastructure — Critical	Page the on-call Infrastructure Lead via PagerDuty immediately. Do not wait for email or Teams. Pro
Infrastructure — High	Create a priority ticket in the operations queue, assign to Infrastructure Team, and notify the team lea
Application — Critical	Page the on-call Application Lead. Simultaneously notify the product owner. Begin rollback preparati
Application — High	Assign to Application Support L2 with the error message and affected service. Determine if the issue
Security — any severity	Notify the Security Response Team immediately via the dedicated security channel (do not use gene
Data — Critical (backup failure 2+ cycles)	Page the on-call Infrastructure Lead and Data Engineering Lead simultaneously. Determine whether
Data — High (backup failure 1 cycle)	Notify Data Engineering Team. Run a manual backup immediately if the system allows it without risk
Data — pipeline failure	Assess which downstream reports or processes are affected. Notify Data Engineering Team and any
User Error — High	Respond to the user with a workaround. Create a ticket for Operations Support to investigate whethe
Unknown classification	Assign to Operations Support for initial investigation. Provide specific investigation questions from Se

7. Management Summary Guidelines

The management summary is a 2-3 sentence description written for a senior manager or executive who does not have a technical background. It answers three questions: What is happening? Who is affected? What is being done about it?

7.1 Writing rules

- Use plain language — no acronyms, no error codes, no technical jargon
- Sentence 1: What is happening and what system or service is affected
- Sentence 2: Who is affected (be specific — 'all users', 'the Finance team', 'external customers')
- Sentence 3: What is happening next (who is handling it, what is the expected timeline)
- Never include speculation about root cause in the management summary
- Never use negative framing ('We don't know what's wrong') — use positive action framing

7.2 Management summary examples

Good example — Critical payment incident

The payment processing service is currently unavailable, preventing customers from completing purchases on the Contoso platform. All customer-facing checkout flows are affected. The on-call engineering team has been paged and is investigating the cause; a rollback to the previous release is being prepared as a contingency.

Good example — Backup failure

The automated overnight backup process failed and did not complete for the last 24 hours. Customer data is not at immediate risk as the previous successful backup from two days ago remains intact. The Data Engineering team is investigating the failure and running a manual backup now to restore the standard recovery point objective.

Bad example — avoid this style

The DB-PROD-02 instance threw an ECONNRESET error on the replication socket during the 02:00 backup window, resulting in a non-zero exit code from the pg_dump process. We are SSHing into the node to investigate.

8. Quick Reference Card

Use this section as a fast lookup during a live incident. For full guidance, refer to the relevant section above.

Scenario	Classification	Severity	Risk	Primary escalation
Production payment service down	Application	Critical	9–10	On-call App Lead
All-user login failures	Application	Critical	8–9	On-call App Lead
Backup not run — 1 cycle	Data	High	6–7	Data Engineering
Backup not run — 2+ cycles or unknown	Data	Critical	8–9	Infra Lead + Data Lead
CPU >95% on production DB	Infrastructure	High	6–7	Infrastructure Team
Server unreachable	Infrastructure	Critical	8–10	On-call Infra Lead
Unusual login pattern / foreign IPs	Security	High	6–8	Security Response Team
Suspected data access by wrong user	Security	Critical	8–10	Security Response Team + CISO
Reporting module slow for all users	Application	High	5–6	App Support L2
Single user cannot access a report	User Error / App	Low–Medium	1–3	Help Desk
Data pipeline missed overnight run	Data	High	5–7	Data Engineering
Automated alert — no context provided	Unknown	High (conservative)	5	Ops Support (investigate)
User permissions request	User Error	Low	1	Help Desk

Remember: When in doubt about severity, choose higher. When in doubt about classification, choose Security or Data if those categories could apply — both have stricter escalation rules that protect the business. A false escalation costs minutes. A missed escalation can cost days.